

Innovative techniques based on traffic analysis and machine learning for malware and botnet detection in real networks

Lorenzo Principi

Co-finanziato da ASTEA SPA

Università Politecnica delle Marche
l.principi@univpm.it

Ottobre, 2024

Attività di ricerca

Obbiettivo di ricerca:

Sviluppo di tecniche innovative di Network Intrusion Detection (NID) attraverso l'utilizzo di strumenti di Machine Learning (ML).

Attività di ricerca

Obbiettivo di ricerca:

Sviluppo di tecniche innovative di Network Intrusion Detection (NID) attraverso l'utilizzo di strumenti di Machine Learning (ML).

Temi di ricerca:

- 1 NID basato su monitoraggio del traffico DNS per rilevamento malware della famiglia DGA utilizzando una rete neurale LSTM.
- 2 Studio evoluzione temporale del traffico malevolo e impatto nella efficienza di rilevazione.
- 3 NID basato su monitoraggio del traffico di una rete locale attraverso la classificazione di metriche ottenute con la Teoria dei Grafi.

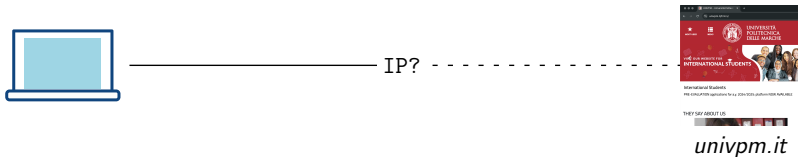
Protocollo DNS

Protocollo Domain Name System (DNS):

- Per gli esseri umani è più facile ricordarsi un nome che un indirizzo IP.
- Attuato automaticamente e *risolve* nomi di dominio in indirizzi IP interrogando i server DNS.
- Utilizzato da alcuni malware per connettersi al server di Command&Control attraverso l'algoritmo Domain Generation Algorithm (DGA).

Protocollo DNS

univpm.it 193.205.131.122

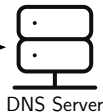


Protocollo DNS

univpm.it 193.205.131.122



Qual è l'indirizzo IP di *univpm.it*?

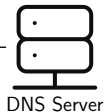


Protocollo DNS

univpm.it 193.205.131.122



L'indirizzo IP è 193.205.131.122



Protocollo DNS



193.205.131.122

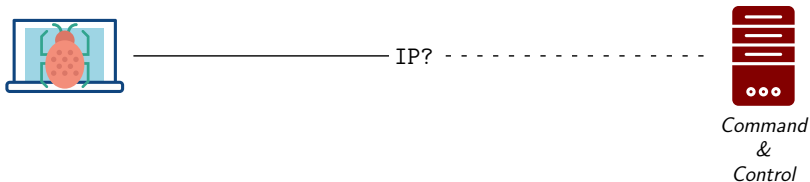


Domain Generation Algorithm

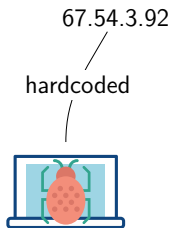


*Command
&
Control*

Domain Generation Algorithm

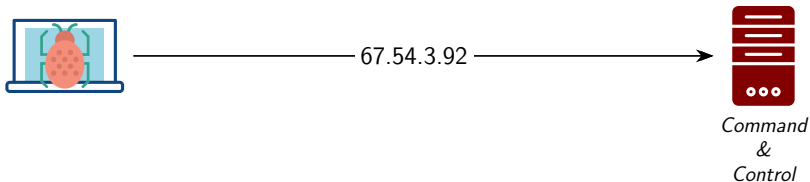


Domain Generation Algorithm

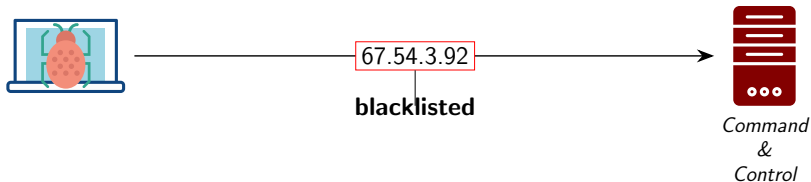


*Command
&
Control*

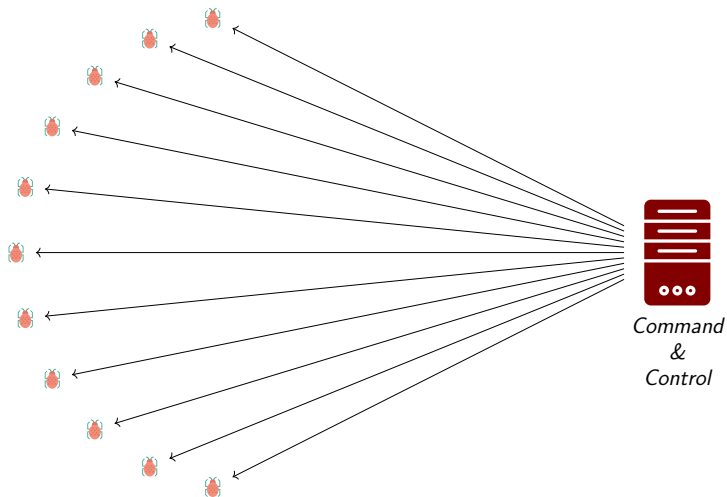
Domain Generation Algorithm



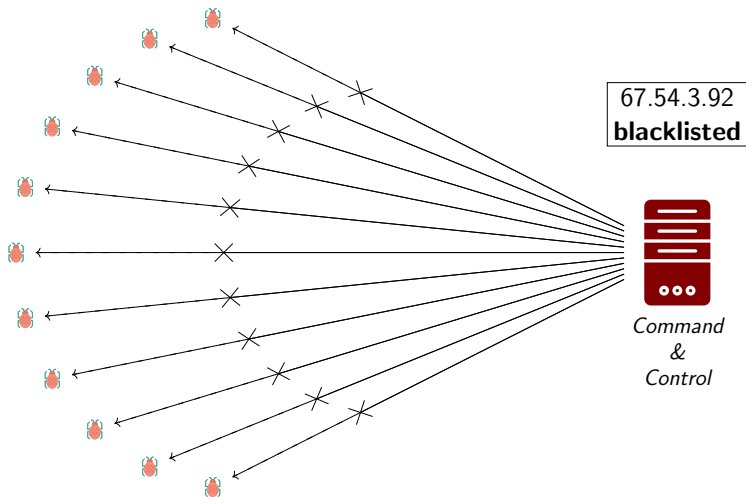
Domain Generation Algorithm



Domain Generation Algorithm



Domain Generation Algorithm



Domain Generation Algorithm



DNS Server



88.76.11.103

axsaoppa.org

Domain Generation Algorithm



DNS Server



registrazione



88.76.11.103
axsaoppa.org

Domain Generation Algorithm



DNS Server



registrazione



88.76.11.103
axsaoppa.org

okrpoisj.org



not found

Domain Generation Algorithm



DNS Server



registrazione



88.76.11.103
axsaoppa.org

okrpoisj.org



not found

acnlxxtamku.ru



not found

Domain Generation Algorithm



DNS Server



registrazione



88.76.11.103
axsaoppa.org

okrpoisj.org



not found

acnlxxtamku.ru



not found

⋮



not found

Domain Generation Algorithm



DNS Server



registrazione

88.76.11.103
axsaoppa.org

okrpoisj.org



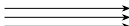
not found

acnlxxtamku.ru



not found

⋮



not found

axsaoppa.org



88.76.11.103

Domain Generation Algorithm



DNS Server



registrazione

88.76.11.103
axsaoppa.org

okrpoisj.org



not found

acnlxxtamku.ru



not found

⋮



not found

axsaoppa.org



88.76.11.103

client



server

Domain Generation Algorithm

- Per ottenere il dominio non c'è scambio di informazioni tra Malware e Command and Control (C&C).
- Se un indirizzo IP viene blacklisted, la procedura riparte in automatico.

Domini DGA

- Sono distinguibili dai domini legittimi.
 - axsaoppa.org
 - okrpoisj.ru
 - acnlxxtamku.org
- Sviluppo rete neurale *Long Short-Term Memory* (LSTM).

Dataset

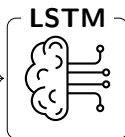
337'500 domini legittimi

Alexa

337'500 domini DGA

Netlab

DGArchive



Domini DGA

- Sono distinguibili dai domini legittimi.
 - axsaoppa.org
 - okrpoisj.ru
 - acnlxxtamku.org
- Sviluppo rete neurale *Long Short-Term Memory* (LSTM).

Dataset

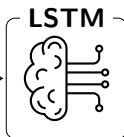
337'500 domini legittimi

Alexa

337'500 domini DGA

Netlab

DGArchive



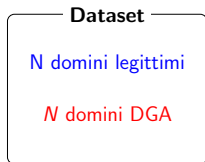
accuracy	0.976
f1-score	0.975
FPR	0.025

Tema 1

Sistema di rilevazione malware DGA basato su monitoraggio del traffico DNS con rete neurale LSTM.

- Approccio con dati reali.
- Utilizza metrica Log-Likelihood Ratio (LLR)

Tema 1: approccio standard



train



test

Classification Metrics

precision

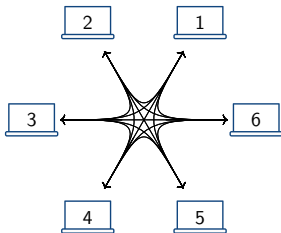
True Positive Ratio (TPR)

False Positive Ratio (FPR)

F1-Score

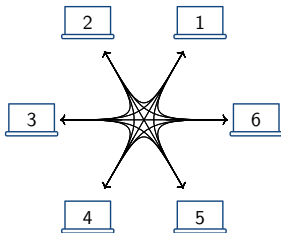
Tema 1: approccio con dati reali

Local Area Network

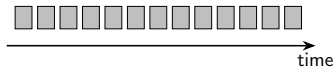


Tema 1: approccio con dati reali

Local Area Network

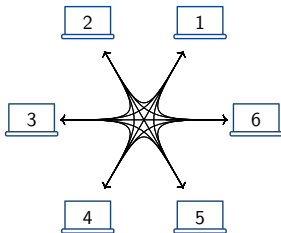


Traffico DNS

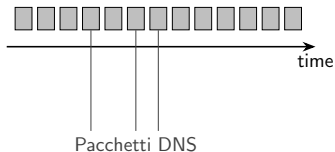


Tema 1: approccio con dati reali

Local Area Network

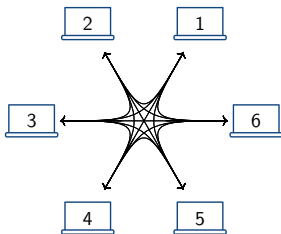


Traffico DNS

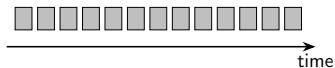


Tema 1: approccio con dati reali

Local Area Network



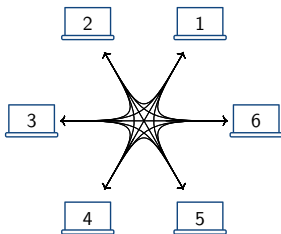
Traffico DNS



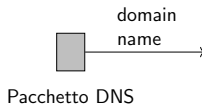
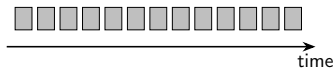
Pacchetto DNS

Tema 1: approccio con dati reali

Local Area Network

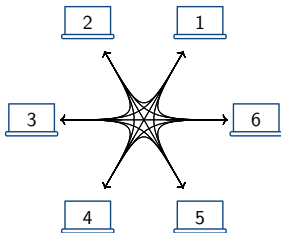


Traffico DNS

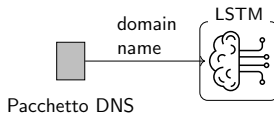
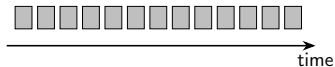


Tema 1: approccio con dati reali

Local Area Network

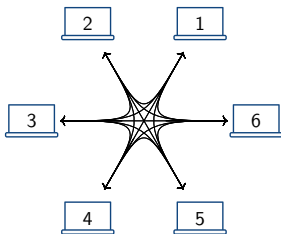


Traffico DNS

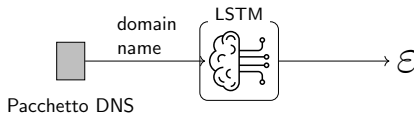
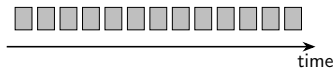


Tema 1: approccio con dati reali

Local Area Network

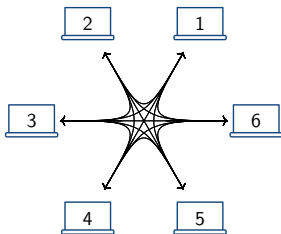


Traffico DNS

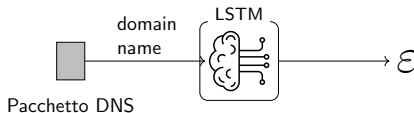
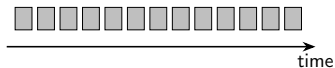


Tema 1: approccio con dati reali

Local Area Network



Traffico DNS



ϵ è la probabilità che il dominio sia DGA.

Generazione allarme

Quando genero un allarme?

Metodo a singolo dominio

- Ogni dominio classificato come DGA genera un allerta.

$$\varepsilon > 0.5$$

Svantaggi:

- Ogni falso positivo corrisponde ad un allarme.

Generazione allarme

Quando genero un allarme?

Threshold-Based Alert

- Raggruppamento temporale (es, pacchetti generati nell'ora x).
- Scelta soglia th .
- Quando il numero di domini classificato DGA supera la soglia th .

$$\left(\sum_i \varepsilon_i > 0.5 \right) > th$$

Svantaggi:

- Ignora le classificazioni legittime (non DGA).

Generazione allarme

Threshold-Based Alert with LLR

- Come il Threshold-Based Alert ma utilizza lo Log-Likelihood Ratio.
- Maggiore flessibilità nella scelta della soglia.

$$\sum_i \log \left(\frac{\varepsilon_i}{1 - \varepsilon_i} \right) > th$$

Risultati

- Dataset formato da Packet Capture (PCAP) ottenuti da Statosphere Repository.
- Analisi parametrica di 256 configurazioni.
- Azzeramento dei falsi allarmi.
- Il rapporto tra allarmi generati e allarmi da generare varia tra 52.2% e 88.2%.

Inoltre:

- Si è dimostrato che le metriche di classificazione non corrispondono alle capacità di rilevamento della minaccia.

Tema 2

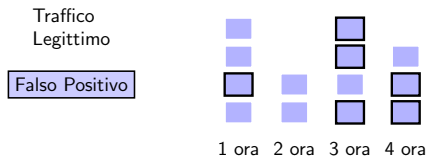
Analisi con traffico reale del sistema di rilevazione malware DGA basato su monitoraggio del traffico DNS con rete neurale LSTM.

- Analisi approfondita approccio con dati reali.
- Analisi diversi tipologie di malware.

Tema 2: approccio standard

Traffico DNS per ora

Positivi per ora

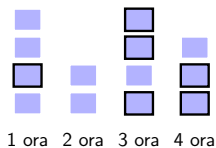


Tema 2: approccio standard

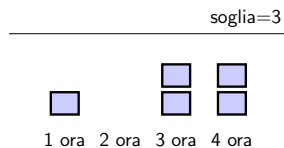
Traffico DNS per ora

Traffico
Legittimo

Falso Positivo



Positivi per ora



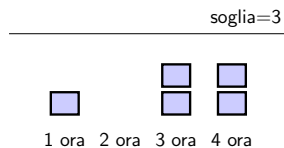
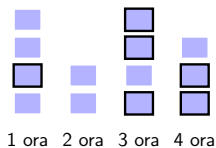
Tema 2: approccio standard

Traffico DNS per ora

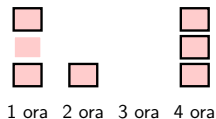
Positivi per ora

Traffico
Legittimo

Falso Positivo



Traffico
Malware 1



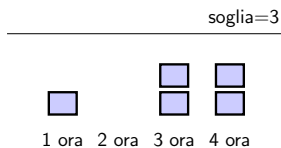
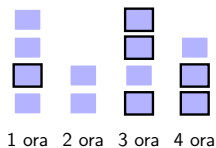
Tema 2: approccio standard

Traffico DNS per ora

Positivi per ora

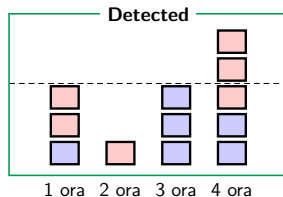
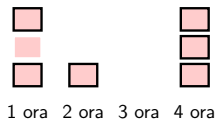
Traffico
Legittimo

Falso Positivo



Traffico
Malware 1

Vero Positivo



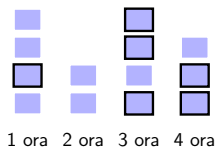
Tema 2: approccio standard

Traffico DNS per ora

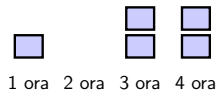
Positivi per ora

Traffico
Legittimo

Falso Positivo

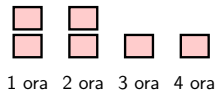


soglia=3



Traffico
Malware 2

Vero Positivo



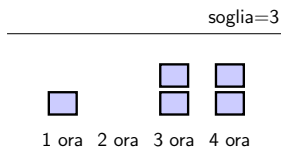
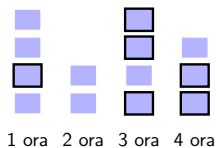
Tema 2: approccio standard

Traffico DNS per ora

Positivi per ora

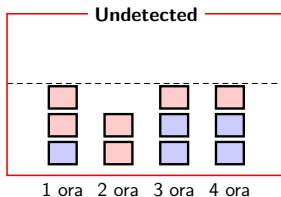
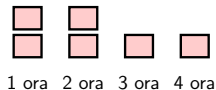
Traffico
Legittimo

Falso Positivo



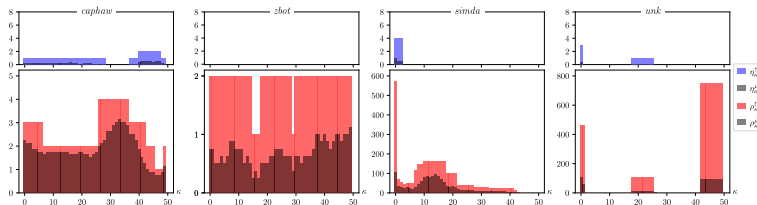
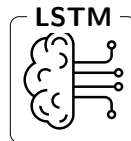
Traffico
Malware 2

Vero Positivo



Data set

- PCAP da Stratosphere repository.
- Un traffico legittimo.
- Quattro diversi traffici DNS malevoli.
 - Malware *caphaw*.
 - Malware *simda*.
 - Malware *virtut*.
 - Malware *zbot*.



Conclusioni

<i>malware</i>	TPR	Ore con attività malevola rilevate
caphaw	0.96	100%
simda	0.95	86%
virut	0.93	36%
zbot	0.94	90%

- L'efficienza di rilevazione dipende dall'evoluzione temporale del traffico malevolo e benevolo.
- Necessario studio di una soglia dinamica.

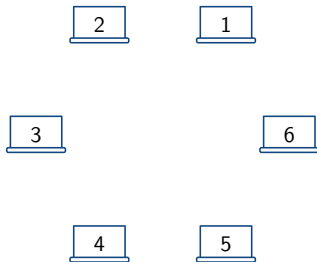
Tema 3

Sistema di rilevazione basato su monitoraggio traffico di rete utilizzando la Teoria dei Grafi.

- Si utilizza un grafo per modellare le connessioni che avvengono in una rete locale.
- **Obiettivo:** Sviluppare un classificatore binario (benevole/malevole) di connessioni basato solo su graph features.
- **Vantaggio:** non analizzando il contenuto dei pacchetti, supera le limitazioni di quando si utilizzano comunicazioni criptate o tecniche elusive.

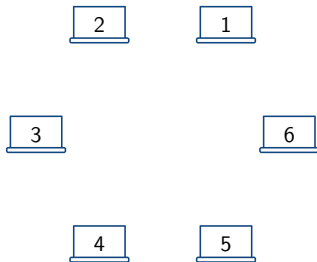
Graph-based NIDS

Local Network

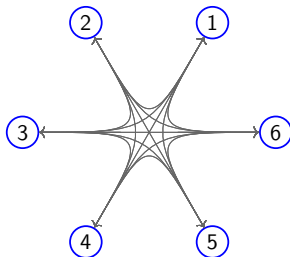


Graph-based NIDS

Local Network

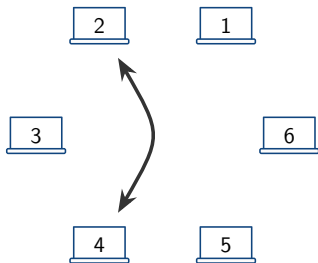


Graph

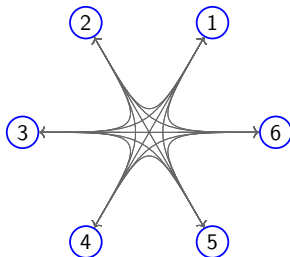


Graph-based NIDS

Local Network



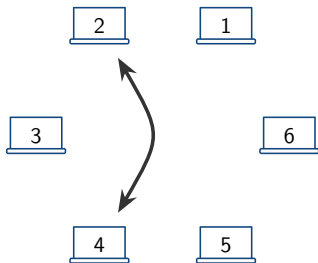
Graph



connessione tra terminale 2 e 4

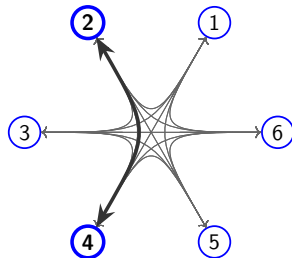
Graph-based NIDS

Local Network



update

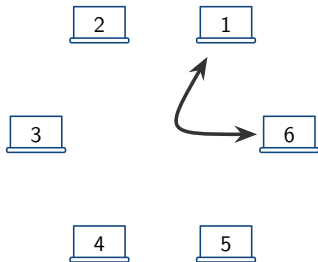
Graph



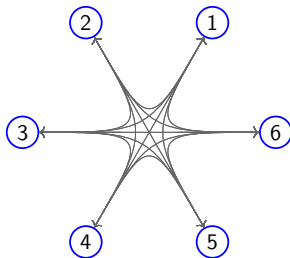
connessione tra terminale 2 e 4

Graph-based NIDS

Local Network



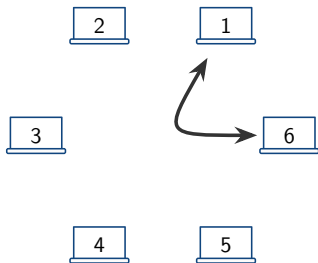
Graph



connessione tra terminale 1 e 6

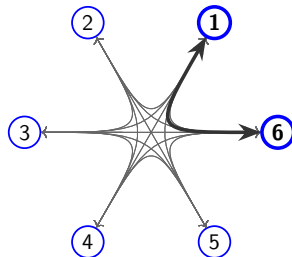
Graph-based NIDS

Local Network



update

Graph



connessione tra terminale 1 e 6

Graph-based NIDS

CIC-2017

*conn*₀

*conn*₁

*conn*₂

*conn*₃

*conn*₄

*conn*₅

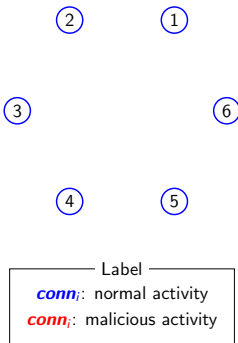
*conn*₆

*conn*₇

*conn*₈

*conn*₉

...



Graph-based NIDS

CIC-2017

*conn*₀

*conn*₁

*conn*₂

*conn*₃

*conn*₄

*conn*₅

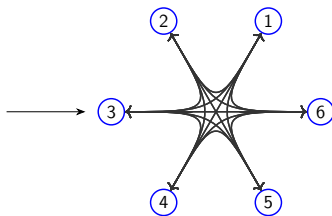
*conn*₆

*conn*₇

*conn*₈

*conn*₉

...



Label

*conn*_i: normal activity

*conn*_i: malicious activity

Graph-based NIDS

CIC-2017

conn₀

conn₁

conn₂

conn₃

conn₄

conn₅

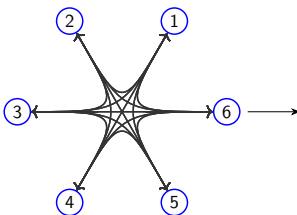
conn₆

conn₇

conn₈

conn₉

...



Label

conn_i: normal activity

conn_i: malicious activity

Graph Dataset

graph features of *conn₀*

graph features of *conn₁*

graph features of *conn₂*

graph features of *conn₃*

graph features of *conn₄*

graph features of *conn₅*

graph features of *conn₆*

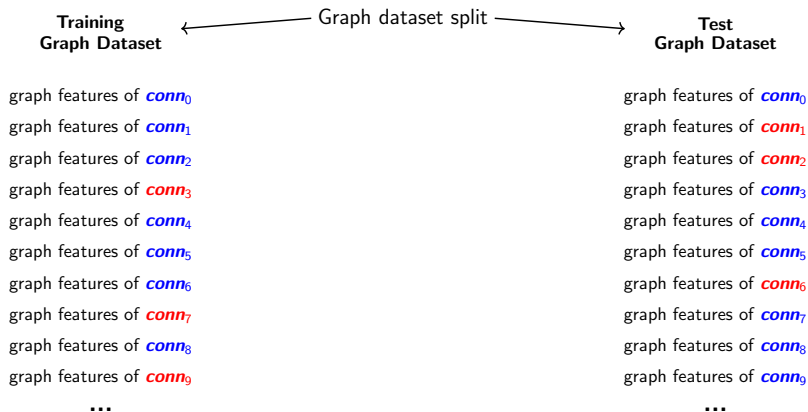
graph features of *conn₇*

graph features of *conn₈*

graph features of *conn₉*

...

Graph-based NIDS

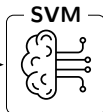


Graph-based NIDS

Training Graph Dataset

graph features of *conn*₀
graph features of *conn*₁
graph features of *conn*₂
graph features of *conn*₃
graph features of *conn*₄
graph features of *conn*₅
graph features of *conn*₆
graph features of *conn*₇
graph features of *conn*₈
graph features of *conn*₉
...

training



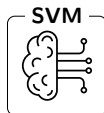
Test Graph Dataset

graph features of *conn*₀
graph features of *conn*₁
graph features of *conn*₂
graph features of *conn*₃
graph features of *conn*₄
graph features of *conn*₅
graph features of *conn*₆
graph features of *conn*₇
graph features of *conn*₈
graph features of *conn*₉
...

Graph-based NIDS

Training Graph Dataset

graph features of *conn*₀
graph features of *conn*₁
graph features of *conn*₂
graph features of *conn*₃
graph features of *conn*₄
graph features of *conn*₅
graph features of *conn*₆
graph features of *conn*₇
graph features of *conn*₈
graph features of *conn*₉
...



testing

Test Graph Dataset

graph features of *conn*₀
graph features of *conn*₁
graph features of *conn*₂
graph features of *conn*₃
graph features of *conn*₄
graph features of *conn*₅
graph features of *conn*₆
graph features of *conn*₇
graph features of *conn*₈
graph features of *conn*₉
...

Graph-based NIDS: results

SVM test metrics

F1 weighted avg	0.9988
-----------------	---------------

Negatives/Benign

False Positives	272
-----------------	-----

F1 score	0.9991
----------	--------

False Positive Ratio	0.0002
----------------------	--------

Positives/Attacks

False negatives	2016
-----------------	------

F1	0.9979
----	--------

False Negative Ratio	0.0037
----------------------	--------

Attività di ricerca: collaborazione con aziende

Collaborazione con aziende o enti pubblici:

- ASTEA SPA:
 - implementazione di applicazioni SIEM QRadar, Netbox.
 - sviluppo applicazione per controllo vulnerabilità degli assets dell'azienda.
- Ancharia SRL: sviluppo applicazione per security assessment di dominio web.
- Regione Marche: studio e progettazione per l'implementazione di uno CSIRT regionale.
- Montimage SRL, Parigi: sviluppo di un test-bed per esperimenti di NIDS su Blockchain DNS.

Attività di ricerca: collaborazione con aziende

Atti di congresso internazionale censito nei database ISI:

- L. Principi, M. Baldi, A. Cucchiarelli, L. Spalazzi, “Efficiency of Malware Detection based on DNS Packet Analysis over Real Network Traffic”, Proc. IEEE CSR 2023, Venice, Italy, July 31 - August 2, 2023.
- Zonneveld G., Principi L., Baldi L., “Using Graph Theory for Improving Machine Learning based Detection of Cyber Attacks”, Proc. IEEE ICMLCN 2024, Stockholm, Sweden, May 2024.
- L. Principi, M. Baldi, “Applying Intrusion Detection based on Algorithmically Generated Domain Classification to Real Network Traffic”, Proc. IEEE CyberComp 2024, Melaka, Malaysia, 6 - 7 November, 2024.